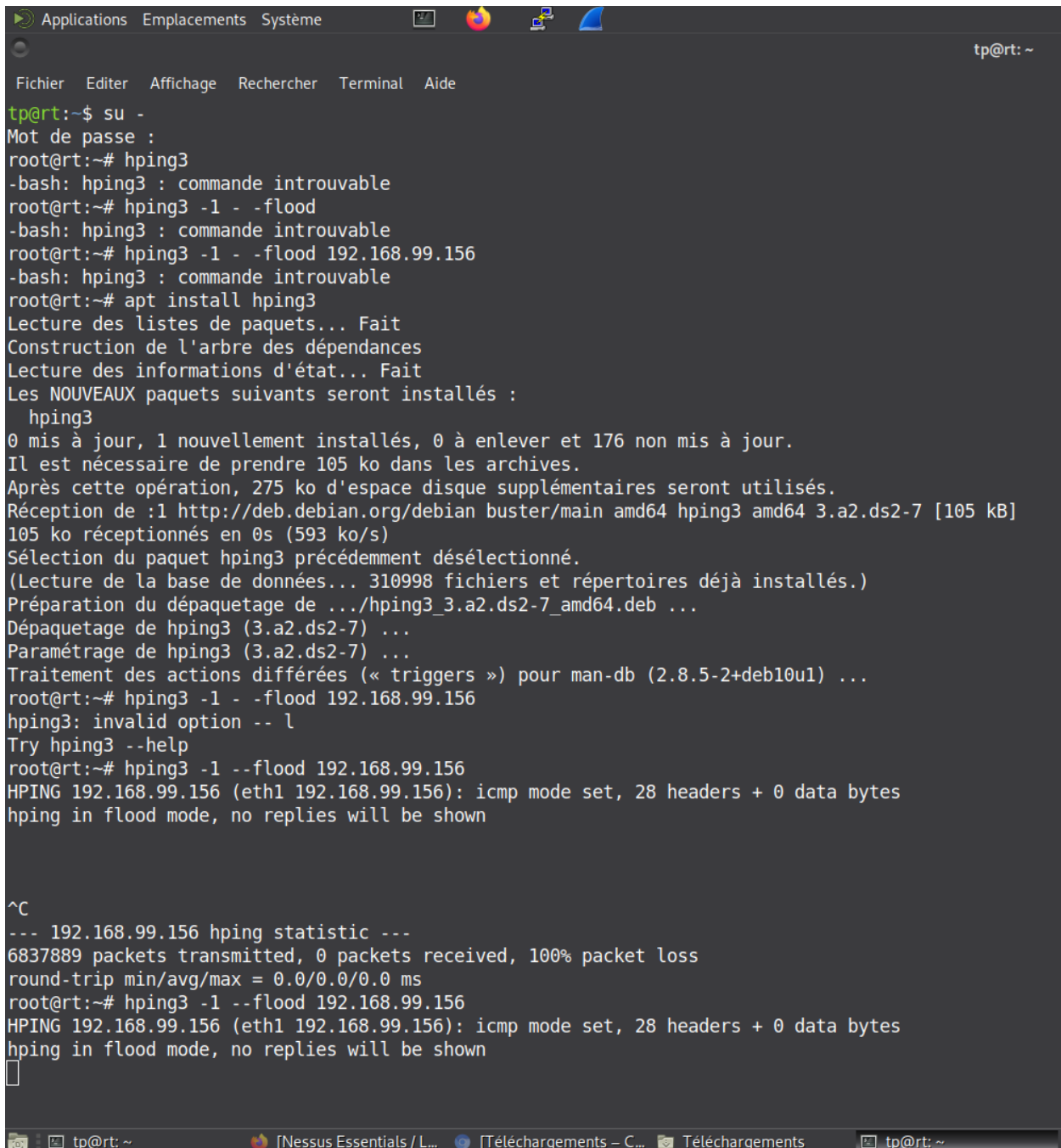


LORENZI Bastien
PISTOLET Florian
JURY—VERMOT DES ROCHES Grégoire

JALON 4 SAÉ 2.4 Projet intégratif

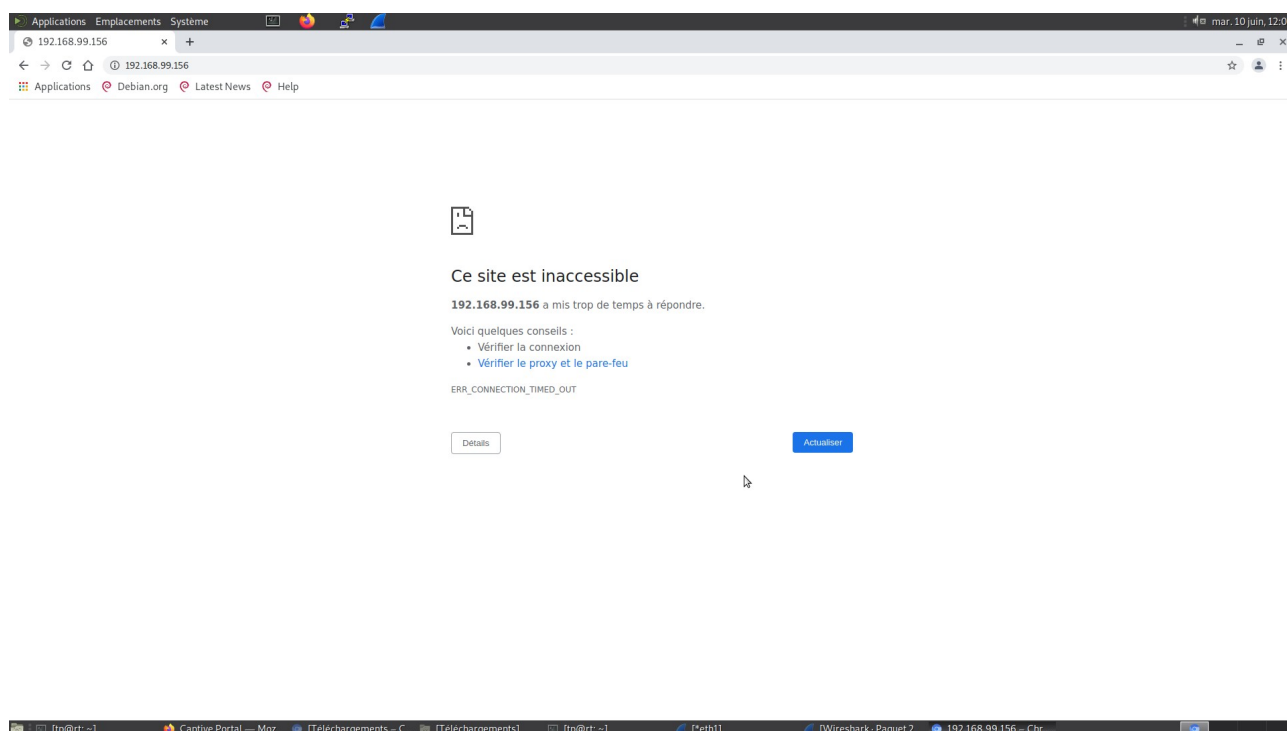
Copie d'écran de la page d'accueil du µc en mode ddos :



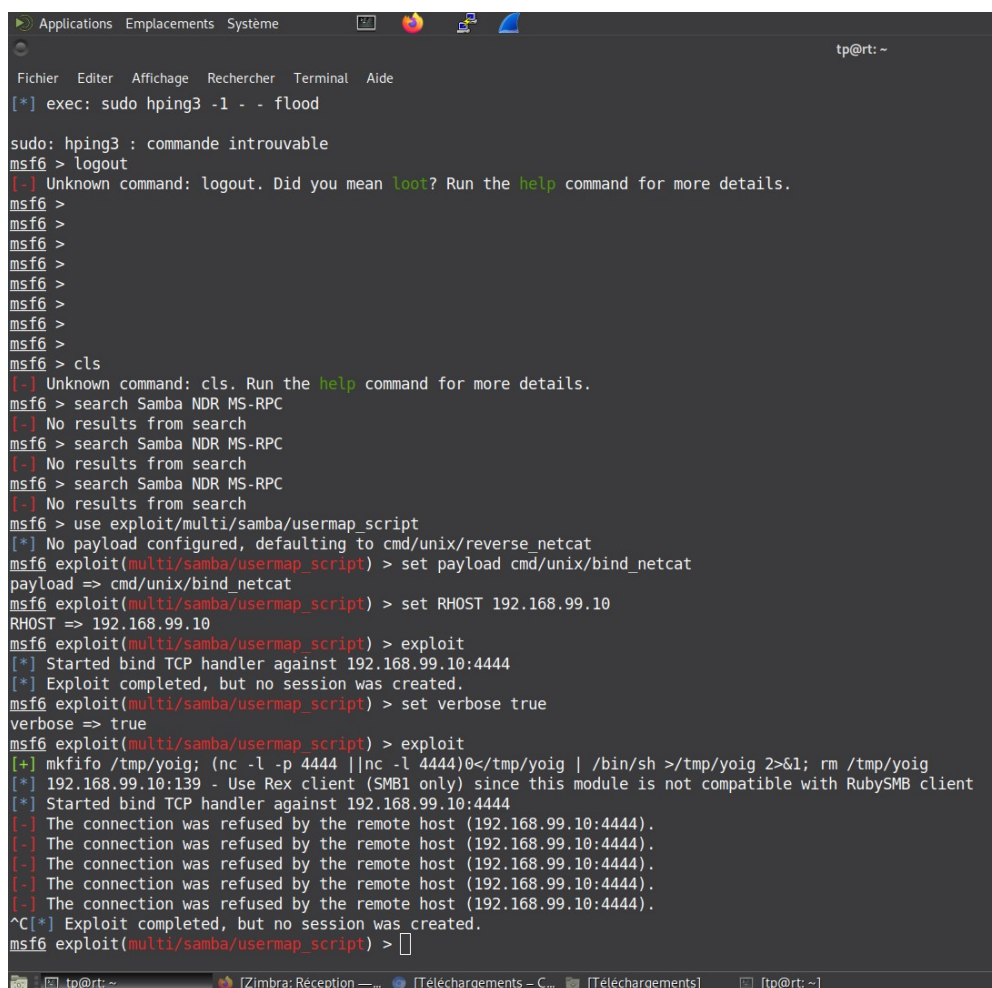
```
tp@rt:~$ su -
Mot de passe :
root@rt:~# hping3
-bash: hping3 : commande introuvable
root@rt:~# hping3 -l -flood
-bash: hping3 : commande introuvable
root@rt:~# hping3 -l -flood 192.168.99.156
-bash: hping3 : commande introuvable
root@rt:~# apt install hping3
Lecture des listes de paquets... Fait
Construction de l'arbre des dépendances
Lecture des informations d'état... Fait
Les NOUVEAUX paquets suivants seront installés :
  hping3
0 mis à jour, 1 nouvellement installés, 0 à enlever et 176 non mis à jour.
Il est nécessaire de prendre 105 ko dans les archives.
Après cette opération, 275 ko d'espace disque supplémentaires seront utilisés.
Réception de :1 http://deb.debian.org/debian buster/main amd64 hping3 amd64 3.a2.ds2-7 [105 kB]
105 ko réceptionnés en 0s (593 ko/s)
Sélection du paquet hping3 précédemment désélectionné.
(Lecture de la base de données... 310998 fichiers et répertoires déjà installés.)
Préparation du dépaquetage de .../hping3_3.a2.ds2-7_amd64.deb ...
Dépaquetage de hping3 (3.a2.ds2-7) ...
Paramétrage de hping3 (3.a2.ds2-7) ...
Traitement des actions différées (« triggers ») pour man-db (2.8.5-2+deb10u1) ...
root@rt:~# hping3 -l -flood 192.168.99.156
hping3: invalid option -- l
Try hping3 --help
root@rt:~# hping3 -l --flood 192.168.99.156
HPING 192.168.99.156 (eth1 192.168.99.156): icmp mode set, 28 headers + 0 data bytes
hping in flood mode, no replies will be shown

^C
--- 192.168.99.156 hping statistic ---
6837889 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms
root@rt:~# hping3 -l --flood 192.168.99.156
HPING 192.168.99.156 (eth1 192.168.99.156): icmp mode set, 28 headers + 0 data bytes
hping in flood mode, no replies will be shown
```

Voici une capture d'écran prouvant que le ddos fonctionne bien puisque nous ne pouvons pas accéder au serveur du micro-contrôleur :

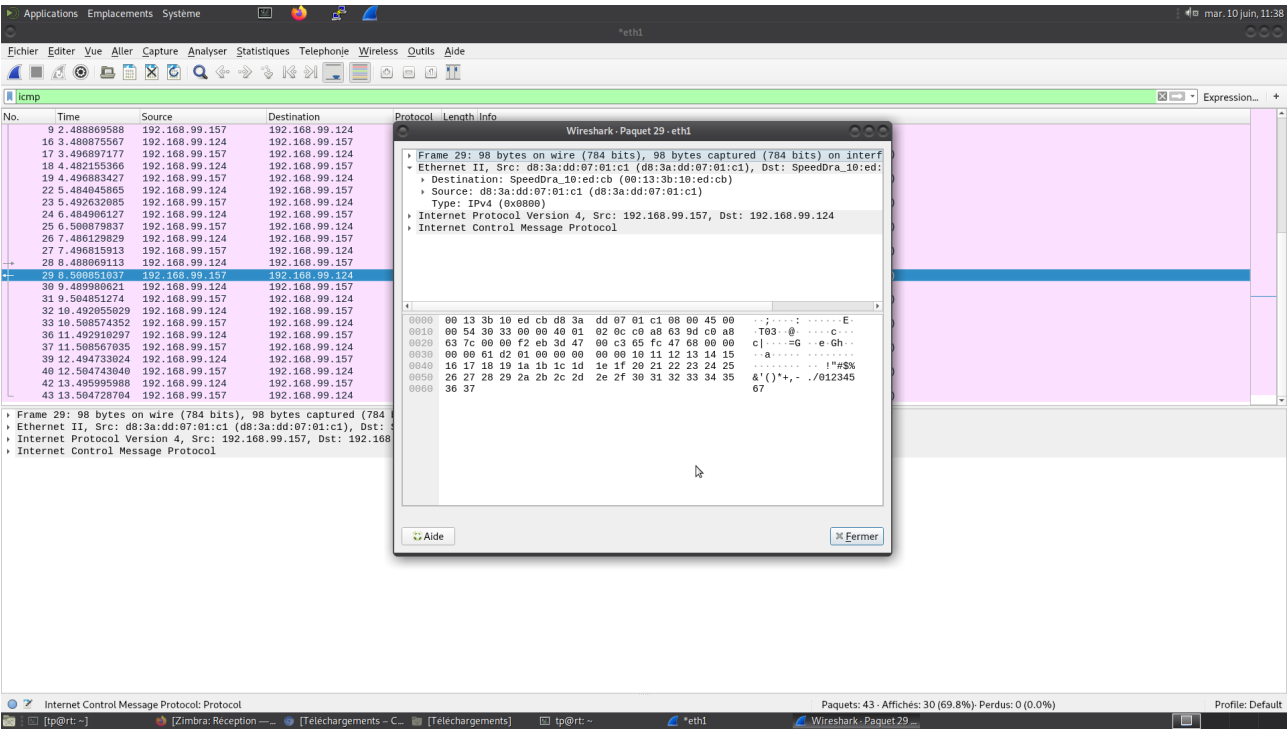


Voici la capture d'écran de la page d'accueil metasploit lors de la tentative d'intrusion :



Nous pouvons voir que la tentative d'intrusion n'a pas fonctionné puisque nous n'avions pas le bon payload.

Voici la capture Wireshark montrant que l'adresse IP du PC 2 (192.168.99.157) est associée à l'adresse MAC de rpi sous kali (d8:3a:dd:07:01:c1) :

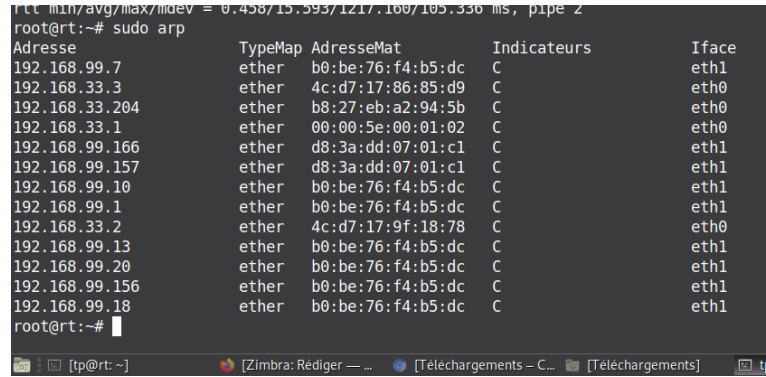


Voici notre tableau d'adressage IP/MAC

K21			
	A	B	C
1		Adresse IP V4	Adresse MAC de la carte réseau
2	PC1 debian	192.168.99.124/24	00:13:b3:10:ed:cb
3	PC2 debian	192.168.99.157	a8:42:a1:ae:98:34
4	Rpi Kali	192.168.99.166/24	d8:3a:dd:07:01:c1

Nous pouvons donc en conclure que le rpi sous kali « vole » l'adresse IP du PC 2 mais se fait trahir par son adresse MAC.

Voici la copie de la nouvelle table ARP commentée d'une des 2 cibles :



En quoi consiste une attaque MITM (Man-In-The-Middle) ?

Une attaque MITM (ou « homme du milieu ») consiste à intercepter, modifier ou espionner une communication entre deux parties (par exemple un client et un serveur), sans qu'elles s'en rendent compte. L'attaquant se place entre les deux pour :

- écouter les échanges (espionnage),
- modifier les messages (altération),
- se faire passer pour l'une des deux parties (usurpation d'identité).

Quel est le protocole des trames envoyées et qui les envoie ?

L'attaque MITM s'appuie souvent sur des protocoles bas niveau, notamment ARP et DNS, selon la méthode employée.

1. ARP Spoofing (ou ARP Poisoning) :

- Protocole utilisé : ARP (Address Resolution Protocol).
- But : associer la propre adresse MAC de l'attaquant à l'adresse IP de la victime ou du routeur.
- Trames envoyées par : l'attaquant, qui envoie de fausses réponses ARP aux deux parties (victime et passerelle).
- Résultat : tout le trafic passe par l'attaquant, qui peut l'analyser ou le modifier.

2. DNS Spoofing :

- Protocole utilisé : DNS (Domain Name System).
- Trames envoyées : fausses réponses DNS envoyées par l'attaquant pour rediriger la victime vers un faux site.

3. HTTPS Downgrade / SSL Strip :

- L'attaquant force une connexion chiffrée (HTTPS) à repasser en HTTP pour lire les données en clair.
- Protocole concerné : HTTP/HTTPS (couche application).